International Journal of Medical Informatics 138 (2020) 104123

Contents lists available at ScienceDirect

International Journal of Medical Informatics

journal homepage: www.elsevier.com/locate/ijmedinf

Evaluation framework for automatic privacy auditing tools for hospital data breach detections: A case study

Tahera Yesmin, Michael W. Carter*

Center for Healthcare Engineering, Department of Mechanical and Industrial Engineering, University of Toronto, Toronto, Canada

ARTICLE INFO

Keywords:
Privacy auditing
Hospital data breach
Inappropriate accesses
Machine learning
Evaluation framework

ABSTRACT

Objective: We aim to 1) design an evaluation framework to examine the accuracy of automatic privacy auditing tools, 2) apply the evaluation method at a hospital to validate the performance of an auditing tool that uses a machine learning algorithm to automate user access auditing, and 3) recommend further improvements in auditing for the hospital.

Materials and methods: Using the black box method of user acceptance testing, we have designed an evaluation framework consisting of appropriate and inappropriate behaviour scenarios to examine the privacy auditing tools. The scenarios were designed from clinical and non-clinical hospital staff perspective, taking expert opinions from the privacy officers and considering examples from the Information and Privacy Commission (IPC) and were tested using Mackenzie Richmond Hill Hospital's data.

Results: The case study using this evaluation framework found that on average 98.09 % of total accesses of the hospital were identified as appropriate and the tool was unable to explain the remaining 1.91 % of accesses. In addition, a statistically significant ($P < 0.05$) increasing trend on categorizing appropriate accesses by the tool have been observed. Furthermore, an analysis of unexplained accesses revealed the contributing factors and found issues related to hospital workflows and data quality (information was missing about staff roles and departments).

Conclusion: Given that adoption of these machine learning tools is increasing in hospitals, this research provides an evaluation framework and an empirical evidence on the effectiveness of automated privacy auditing and detecting anomalies for dynamic hospital workflows.

1. Introduction

Hospitals worldwide are shifting from a paper-based system to computerized databases and inter-connected systems with expectations to improve communication, facilitate clinical decision making and enhance the quality of care by promoting the access of the right information at the right time by the right stakeholder [1]. On the other hand, as digitalization efforts progress, hospitals are experiencing an increase in data breaches [2]. Data breaches occur when patient's protected or personal health information (PHI) are inappropriately accessed by hospital employees or by cyber-security hackers [3,4]. Healthcare data breaches cause a healthcare provider data loss, financial loss, reputational damage, and affect medical devices, infrastructure and patient safety [5–9]. Research by Ponemon Institute reports a data breach costs a healthcare provider an average of $408 per record, three times higher than the cross-industry average of $148 [10]. Furthermore, researchers in one paper provided evidence that data breaches can affect patient safety by increasing a hospital's 30-day acute myocardial infarction (AMI) mortality rate for the years following the breaches but no direct causations were mentioned in that paper [5].

Being vulnerable to data hacking, hospitals are continuously trying to ensure privacy protection by adopting various methods including encrypted devices, strong passwords, two-factor authentication, employee privacy training, signing confidentiality agreements annually, and self-audit tools for employees to see who has viewed their records [11,12]. However, many hospitals still monitor and audit the access of PHI in a reactive manner, for example in response to a patient complaint or some other event that necessitates an investigation. Ontario Information Privacy Commissioner (IPC), has set out several requirements including that hospitals be able to log, audit, and monitor all instances of an access of PHI in all electronic information systems [13]. Similarly, in the USA under the Health Insurance Portability and Accountability Act (HIPAA) Security Law, hospitals are obliged to have procedures and policies to prevent, detect, contain and correct security

* Corresponding author.
E-mail addresses: tahera.yesmin@mail.utoronto.ca (T. Yesmin), mike.carter@utoronto.ca (M.W. Carter).

https://doi.org/10.1016/j.ijmedinf.2020.104123
Received 16 December 2019; Received in revised form 15 February 2020; Accepted 18 March 2020
1386-5056/ © 2020 Elsevier B.V. All rights reserved.

violations. Implementing hardware, software and procedural processes are required to record or examine activities in information systems that contain electronic personal health information (ePHI) [14,15]. The 2017–2018 HIPAA compliance checklist suggested regular monitoring and auditing of ePHI access logs as well.

Considering the law and the damages associated with data breaches, hospitals are required to conduct proactive auditing and monitoring. Research suggests that technological tools applying machine learning or artificial intelligence, compared to manual auditing, can increase data breach detection by continuously and automatically monitoring access logs [8]. Furthermore, researchers have demonstrated how auditing solutions can be built using machine learning algorithms and provided some examples of the working methodologies and performance of those tools in their studies. For example, researchers [12,16–18] showed how machine learning algorithms can categorize all accesses and identify potential breach cases for hospitals without human interaction. They demonstrated in their studies that all hospital data can be automatically audited by these tools and thus can enhance patient safety.

The adoption of these machine learning tools is increasing in hospitals, but no studies have been conducted to validate the effectiveness of these tools for dynamic hospital workflows. Similarly, there is no existing framework for evaluating the effectiveness of these automatic auditing tools adopted by the hospitals. Therefore, this research aims to develop an evaluation framework to evaluate automatic privacy auditing tools at the hospitals and later apply the framework to a case hospital for reporting the success of such tool to identifying inappropriate accesses.

2. Challenges in proactive auditing

In practice, some hospitals are shifting to proactive audits, but in a very infrequent manner. Canadian Healthcare Technology published survey results on the auditing behaviour of 22 hospitals in Ontario, Canada and reported that the frequency of the audits varies widely: daily (1), weekly (2), monthly (10), every two to three months (1), quarterly (1), no set frequency (6), and unclear frequency (1) [19]. Though the hospitals want to conduct proactive auditing continually, the consistency varies due to various challenges. Some of the challenges are:

i **One or few privacy officers to audit million of records**: Numerous records on each patient [20] stored in each EHR making it impossible for one or few privacy officers with intense workload [21] to conduct frequent proactive auditing.

ii **Dynamic workflows:** Healthcare is known for its dynamic workflows [22] due to its open, fluid and flexible environment. Staff workflows vary to adjust to demand fluctuations or disastrous situations. Many staff access PHI of patients they are not accountable for (they are outside the patient's circle of care) for various unique but valid workflows.

iii **An improper mapping between various data sources:** Due to digitalization, hospitals now have many systems to manage their data such as human resource software, EHR or scheduling software. Unlike other organizations, most systems are not purchased from a single IT organization or provided by the medical device companies [8,23]. Mapping the information on the staff identifiers, for example, might be a challenge in such cases.

iv **No set rules for auditing:** There are no set rules for the privacy officer to conduct their auditing [19]. Given the complexity of hospital workflows, audits vary in frequency and in magnitude.

3. Evaluation framework

The main objective of this evaluation framework to i) examine the accuracy of the performance of the automatic privacy auditing tool at hospitals. Apart from that, the results from this evaluation can also be used to ii) identify any trend in the data and thereby can be iii) analyzed to help the hospital to improve their performances in detecting breaches with the help of these auditing tools.

3.1. Framework development-scenario testing

3.1.1. Design of the scenarios

The evaluation framework was developed adapting the concept of black box method of user acceptance testing [24–27], where various scenarios were designed for the purpose of validation. Black box testing, sometimes called functional testing [28], uses specific information to design test cases, where the tester does not have access to the interior configuration, or implementation of the tested item. Thus, this method does not deal with internal mechanisms, but focuses on the output generated from specific input.

A few studies are available where scenarios have been used by the researchers for similar purposes or case studies have been conducted to assess any privacy related tool for hospitals. In one study, researchers [29] used various breach examples to identify the gap between HIPAA policies and reported breaches through semantic similarity metric. In another study [30], researchers conducted a case study to assess the security risk of a small dental clinic using the security risk assessment tool recommended by the federal government. However, no studies have been found that design an evaluation framework and evaluate the hospital privacy auditing tool based on that.

Literatures report that insider snooping is one of the widely mentioned reasons of hospital data breaches [31,32]; therefore, scenarios related to insiders' (nurses, physicians, vendors, contractors, and others) valid workflows and breach cases were used in this framework to validate the outcome of the tool. Valid workflows of the employees were named as appropriate and invalid workflows (breach cases) as inappropriate behaviours.

Considering various workflows and the dynamic nature of hospital processes [33,34], six different categories were considered while designing the scenarios to include broad categories of insiders' behaviors:

- **User types:** Scenarios including both clinical and non-clinical staff (physicians, nurses, finance, etc.).
- **Patient types:** Scenarios involving inpatients, outpatients, or emergency patients.
- **Assigned role types**: Scenarios considering various staff roles in different networks of care; for example, whether the staff member is part of the patient's treatment team (circle of care).
- **Missing information:** Scenarios designed considering cases if information is missing in the network of care; for example, if the assigned nurse's information has not been documented in the EHR.
- **Schedules:** Scenarios including cases in which staff access past patient data, cases in which staff were on-call, or accesses from outside the hospital.
- **Volume of the accesses**: Scenarios involving a large number of accesses to patients' PHI.

a) Scenarios related to appropriate behaviour: Based on the above mentioned six categories, scenarios related to appropriate behaviours were designed. Daily activities of the clinical and non-clinical staff of a hospital were identified with the help of the privacy officers of three hospitals in Ontario, Canada (Mackenzie Richmond Hill Hospital, Markham Stouffville Hospital and Michael Garron Hospital), the staff from Mackenzie Richmond Hill Hospital and from literature [33,34] to design the appropriate behaviour scenarios. Appropriate behaviours can be categorized into two types i) common appropriate (regular, frequent, and valid workflows) and ii) unique appropriate (infrequent but valid workflows). Examples of unique appropriate behaviours are:

- Peer to peer consultation: staff access a patient's chart because one of their co-workers asked for a consultation through in-person

request, email or phone call.

- Vacation coverage/casual break coverage: One peer covers another peer during break/vacation.
- Wrong MRN/name: Staff accidentally accessed the wrong patient's chart.
- Outside hospital access: Physicians work on their billings outside the hospital; nurses review charts offsite.

b) Scenarios related to inappropriate (breach) behaviour: Similarly, to design scenarios of inappropriate behaviours from the literature [35], expert opinions on healthcare breach cases from privacy officers and real-life breach cases from IPC of Ontario were considered. Common illegitimate behaviours were called common inappropriate and infrequent (rare) inappropriate behaviours were called unique inappropriate. Most of the cases on common inappropriate insiders' behaviour from the literature [36,37], and from the experts included scenarios of similar types, where staff accessed family members' charts, neighbours' charts, co-workers' profiles, deceased patients' charts, sensitive/VIP patients' charts, discharged patients' charts, their own emergency contact's profile and their own profile for no clinical or operational reasons.

3.2. Execution of the evaluation framework

3.2.1. Validation

To validate the appropriate behaviours, the hospital can compare the valid workflows of the formerly selected staff against the tool's output by reviewing the results with the staff. If the behaviour is appropriate and the tool also labeled it appropriate, we can consider that a correct assessment by the tool; but if the tool identifies the access differently, then we consider that an incorrect assessment. Fig. 1 shows the framework of the evaluation strategies for any automatic privacy auditing tool.

3.2.2. Analysis of the results

In this phase, the results and any other suitable data (for example, trend of the tool or miss-identified user behaviours) will be analyzed to provide further recommendations.

4. Application case

4.1. Hospital profile and the privacy tool

This research was conducted at the privacy departments of one of the pioneering hospitals that adopted an integrated and connected health system [38], Mackenzie Richmond Hill Hospital (MRHH), Ontario, Canada. With one privacy officer, manual monitoring of each of the 55,000 accesses processed by MRHH every day, was not possible. Therefore, MRHH aimed to implement a proactive solution that would automate their manual auditing system, meet IPC's requirements and identify unauthorized accesses while ensuring barrier-free access to information for authorized purposes when needed.

After going through a systematic approach of procurement, MRHH selected Explanation-Based Auditing System (EBAS) to run for a pilot phase of six months. The EBAS audit tool [17,18,39], uses interrelated clinical and non-clinical staff and patient information from any EHR and other sources as input and applies supervised machine learning algorithms to automate audits of staff accesses and creates tailored explanations and classifications for each organization's data to detect unauthorized accesses in a timely manner. As this tool is based on supervised machine learning algorithms, with the help of appropriate data it learns over time to improve its accuracy. It also allows the privacy officers to provide their organization specific requirements such as, customized accesses action whitelists (specific access actions that should always be considered appropriate), a VIP patient list, a watch list (assigned to a user to ease closer monitoring of their EHR access behavior), a saved search option (any searches can be saved for a continuous review later), etc. to improve the performance of the tool for their hospital.

EBAS categorizes all the accesses into three following classes:

Appropriate:	When EBAS finds a valid explanation of an access, it marks the access as appropriate.
Unexplained:	When there is no clinical and operational reason found by EBAS for an access, it is marked as unexplained.
Flagged:	Potentially high-risk unexplained accesses are marked as flagged. By default, the unauthorized access of the PHI of family members, co-workers, neighbours or self-accesses are marked as flagged by this tool. Staff or patients living within a short distance of each other, either currently or in the past (distance default is 0.25 miles) is considered as neighbour.

At MRHH, data from three sources (an EHR, a human resource software and a scheduling software) on users (ID, name, work schedules) and on patients (ID, name, gender, date of birth, home address, diagnosis, etc.) were provided as input for EBAS to run to identify and categorize accesses, and to provide explanations as outputs. These outputs from EBAS were then used to validate the effectiveness of this machine learning tool to identify unauthorized accesses and deliver recommendations to help MRHH to improve their privacy procedures

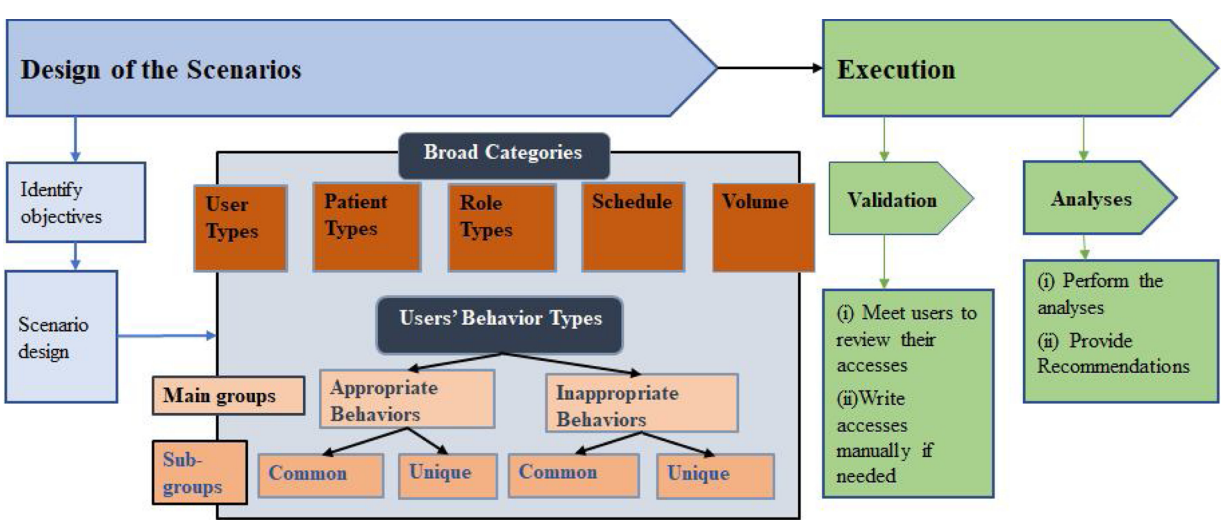

Fig. 1. Evaluation framework for automatic privacy auditing tools.

Table 1
Appropriate accesses (%) of the users on the day of the interview.

No.	User Type	User Role	Departments	*On the day of the interview*						
				Total Number of Accesses	Appropriate Accesses		Unexplained Accesses		Flagged Accesses	
					(in number)	(%)	(in number)	(%)	(in number)	(%)
1	Clinical	Clinical Pharmacist	Pharmacy	37	29	78.3	8	21.7	0	0
2		Registered Dietician	Clinical Nutrition Medicine	12	12	100	0	0.0	0	0
3		Social Worker	Social Work-Medicine	13	12	92.3	1	7.7	0	0
4		Clinical Utilization Co-ordinator	Emergency	56	52	92.9	4	7.1	0	0
5		Manager, Patient flow	Clinical Utilization Services	58	6	10.4	52	89.6	0	0
6		Physician	Medicine-ICU	29	29	100	0	0	0	0
7		Physician	Medicine	19	19	100	0	0	0	0
8		Physician	Medicine-Neurology	114	91	79.8	23	20.2	0	0
9	Non-Clinical	Manager, Patient Access	Patient Access Services	4	4	100	0	0	0	0
10		Patient Access Representative	Patient Access Services	85	76	89.4	9	10.6	0	0
11		Supervisor, Patient Accounts	Financial Services	40	0	0	40	100	0	0
12		Co-ordinator, Health Record	Health Information Services	23	11	47.8	12	52.2	0	0
13		Coder	Third Party	51	0	0	51	100	0	0

using our evaluation framework.

4.2. Conducting the case study

This study was conducted from November 2017 until June 2018. 13 clinical and non-clinical staff were selected (Table 1) to validate the appropriate behaviour scenarios. Designed inappropriate scenarios were used for the validation of inappropriate behavior. Some of the appropriate scenarios, for example staff accessing their family members' profile for valid clinical or operational reason, and all the inappropriate scenarios that we designed for the validation were not found in the daily activities of the staff and also changing the real live production data were restricted; therefore, we manually constructed the access logs for these scenarios from the copies of production access log extracts. Later, the tool's responses to these scenarios were assessed by the researchers.

In addition to the scenario validations, changes in MRHH's daily trends of appropriate, unexplained, and flagged accesses were tracked and analyzed to assess the performance of the tool over time to provide recommendations.

5. Results

5.1. Ability to categorize staff accesses

5.1.1. Validation of appropriate behaviours

Reviewing accesses with the staff reported three main findings:

(i) Daily accesses for most of the clinical staff with regular roles were identified as appropriate (both common and unique workflows). However, many accesses by clinical staff with exceptional roles were unexplained by the tool. For example (Table 1), a manager from the patient-flow department reads various patient charts to monitor patient movements between departments. Since this workflow is not always documented or have work orders to authorize access to PHI, 89.6 % of the nurse manager's accesses were unexplained on the day when the researchers reviewed their accesses with the staff. In another occasional case, a physician from medicine-neurology, affiliated at multiple hospitals attending patients at multiple sites, appeared to create unexplained variations and therefore unexplained by the tool.

(ii) Table 1 also shows that the number of unexplained accesses was more for non-clinical staff. For example, 100 % of the accesses by the supervisor of patient accounts (financial services), 52.2 % accesses of the health records co-ordinator (health information services) and 100 % of the accesses by the coder were unexplained on the day of the review. Since they accessed patient charts due to phone calls, personal requests or work orders that come from different databases, the tool could not find any clinical or operational reason to explain their activity.

(iii) As mentioned earlier, we were unable to find real-life examples for a few appropriate scenarios where a user accesses their family member's chart, neighbour's chart, own chart, deceased patients' chart, etc. for valid clinical and operational reason. We manually created examples to validate the outcomes from the tool. The results concluded two main findings: out of 16 manually created appropriate common behaviour scenarios, 14 returned expected (including the unique scenario) results; and only two showed unexpected results. Those two scenarios were related to a patient encounter that was more than 32 days before the access date. Currently, any PHI access that occurs more than 32 days before or after a patient encounter, is not considered a general practice by the tool and is thus unexplained. This timeframe (32 days) can be changed within the tool based on the hospitals' policy. Please see Supplementary Table 1 for more details.

5.1.2. Validation of inappropriate behaviours (breach cases)

Twenty-one fictitious common and unique inappropriate cases were created using real MRHH staff information and fake patients to validate the inappropriate behaviour scenarios.

(i) Nine scenarios involving same last name, same neighbourhood, own profile, and an example from IPC were all alerted as high-risk accesses by the tool, as expected by MRHH.

(ii) Ten of 21 scenarios (both common and unique) relating to deceased patients, a sensitive patient, multiple chart reviews and an example from IPC were expected to be alerted as high-risk, but the tool labeled the accesses as unexplained, not high-risk. The tool currently alerts inappropriate scenarios automatically as high risk when there is last name match, full name match, neighborhood match or access of a co-worker's PHI. Since our executed scenarios did not meet any of the above criteria, the scenarios were not alerted as high-risk automatically. However, the tool's 'saved search' option can be used to set alerts for inappropriate accesses of any kind.

(iii) The remaining two scenarios related to accessing patients' charts

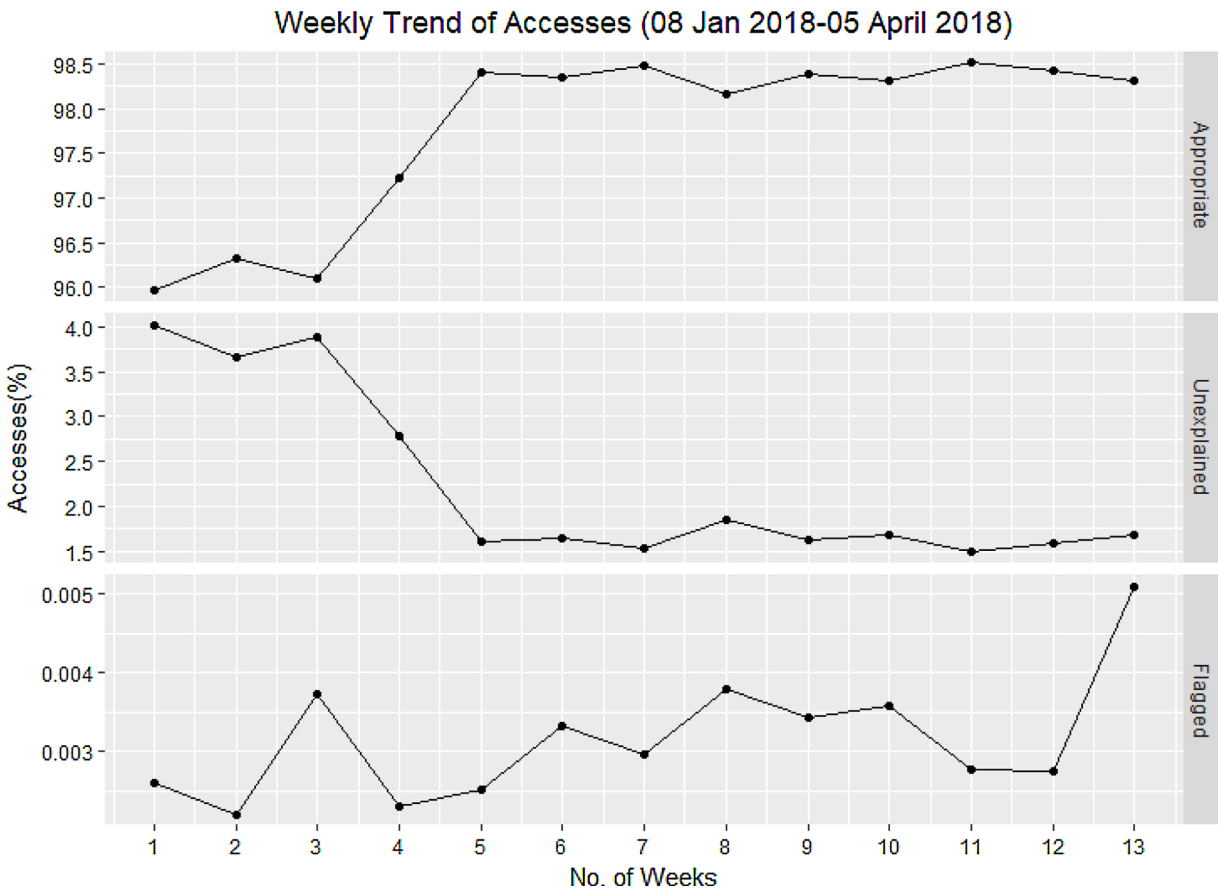

Fig. 2. Weekly trend of three types of accesses (08 January -05 April 2018).

from the previous day for no clinical or operational reason, were labeled appropriate. Due to current policies, the tool does not flag the access of patient charts from the previous day to ensure proper delivery of care; this can also be changed if the hospital desires.

5.2. Examine the change in the performance of the tool for MRHH staff over time

We analyzed the tool's results for MRHH staff accesses over time from January 08 to April 05, 2018. Majority of the data was provided to the tool at the beginning, however, a continuous customization on access action whitelists specific to MRHH, a VIP patient list, etc., had been conveyed from MRHH to the tool vendor. Later, additional data on the treatment team, appointment visits provider, follow up provider, a list of dead patients were provided to help the tool analyze the data better. Consequently, it was essential to examine how the tool performs over time. Fitting an exponential non-linear curve shows a statistically significant ($P < 0.001$) increasing trend in identifying appropriate accesses, a decreasing trend in unexplained accesses and a non-significant trend for flagged accesses. Fig. 2 illustrates that after week five, when the tool has enough data to assess all workflows and to relate the operational or clinical reasons for the accesses, its performance improves and stays steady afterward for both appropriate and unexplained.

The average of different categories of accesses after week five (23 January – 05 April, 2018) in Table 2 shows that mean weekly appropriate accesses is 98.09 % and mean unexplained accesses is 1.91 % of total PHI accesses.

Further analysis (Fig. 3) of accesses by the day of the week identified that average appropriate accesses were higher on Saturday (98.85 %) and Sunday (98.67 %) than the rest of the week. Average unexplained and flagged accessed decreased during weekends. Absence of non-clinical activities during weekends might explain this observed pattern of higher appropriate and lower unexplained accesses during the weekend.

Table 2
Different average weekly accesses (%) found by the tool.

	Min	Max	Mean
Appropriate accesses (%)	95.57	99.01	98.09
Unexplained accesses (%)	0.99	4.43	1.91
Flagged accesses (%)	0.00	0.01	0.003

5.3. Analysis of the unexplained accesses of MRHH staff

The majority of the accesses (average 98.09 %) were identified as appropriate accesses, with only average 1.91 % unexplained accesses. However, this 1.91 % contained around 5609 accesses per day, which implies that the privacy officer would need to manually audit approximately 5609 unexplained accesses daily to determine potential breaches; clearly, this is not feasible. Thus, to facilitate the reduction of unexplained accesses and further automation of the privacy audit, we conducted a detailed analysis of unexplained accesses for seven days-worth of data (24–30 March 2018) to identify the prime contributors of unexplained accesses based on MRHH staff roles, departments, and names.

During these 7 days, the tool marked 39,263 unexplained accesses for 1367 employees with 52 various roles across 120 departments.79 % of these unexplained accesses were contributed by a 42 % of users whose information on their roles and departments were missing in the data (569 out of 1367). The majority of the users (58 %) with correct information on role and departments contributed to the remaining 21 %

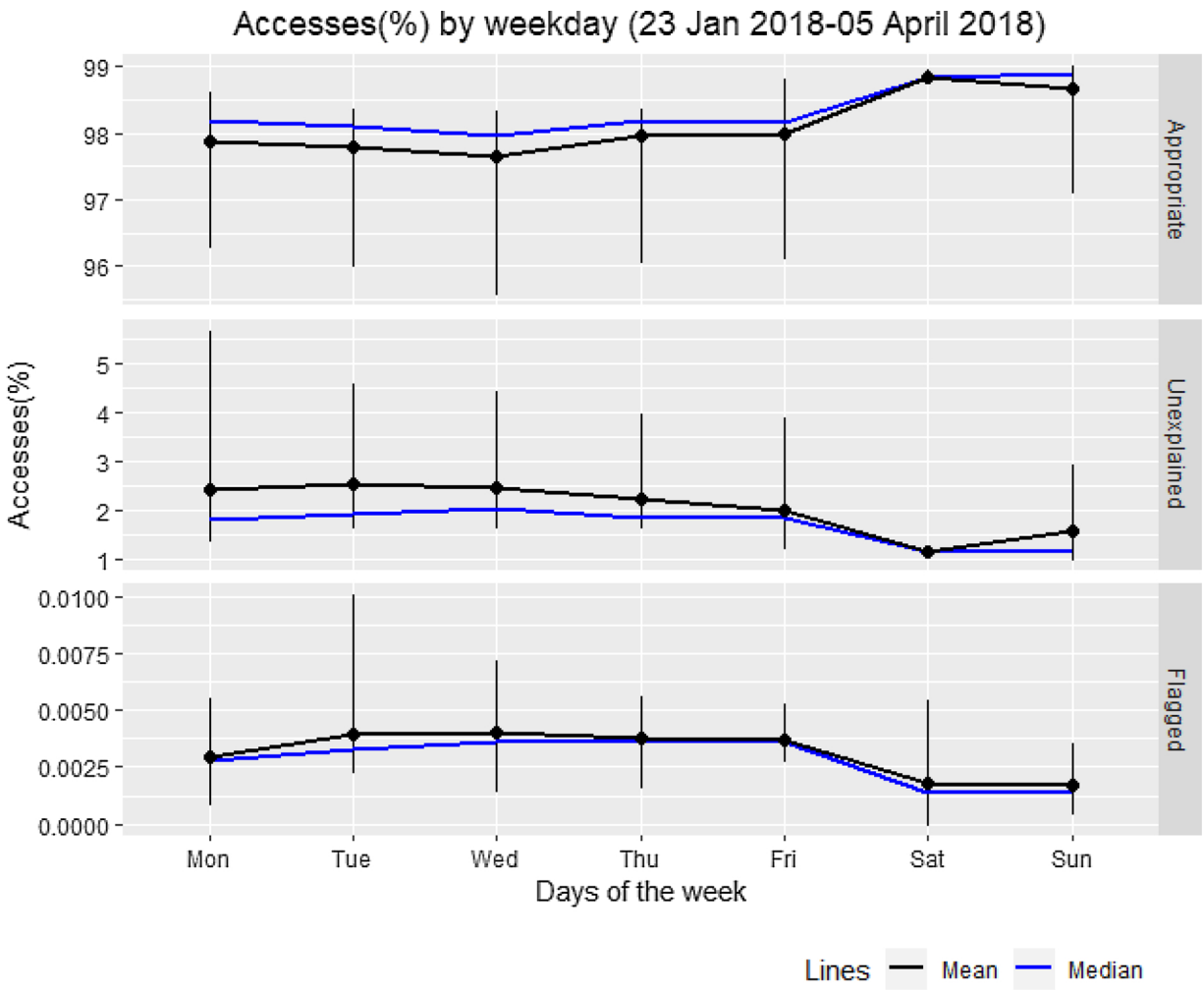

Fig. 3. Accesses by weekday for all access types.

Table 3
Missing information observed in unexplained accesses (24-30 March 2018).

Missing information	No. of users (% of total)	No. of unexplained accesses (% of total unexplained accesses)
Missing role information	443 (32.41 %)	29,649 (75.51 %)
Missing departments information	305 (22.31 %)	12,310 (31.35 %)
Missing both role and departments information	179 (13.09 %)	10,949 (28 %)
Missing either one information (role or departments)	390 (28.52 %)	20,061 (51 %)
Both role and departments info present	798 (58.39 %)	8253 (21 %)

of unexplained accesses shown in Table 3. Clearly, missing information has an impact on accesses being unexplained.

Further analysis to identify the contributors of unexplained accesses based on role reported that the main contributors (75.51 % of total unexplained accesses) are 443 users (32.41 % of total users) who are missing assigned roles data (Table). Clinical pharmacists, who are just 2.19 % of the total staff, are the second highest contributors with 1.18 % of total unexplained accesses. Physicians (11.92 % of the total staff) and registered nurses (19.31 % of total staff) are the third and fourth highest contributors being responsible for 0.09 % and 0.04 % of unexplained accesses respectively.

Analyzing users' departments revealed that a significant number of unexplained accesses involved non-clinical departments where the specimen procurement departments, financial services, hemodialysis, and pharmacy are contributors of 6.73 %, 6.59 %, 4.98 %, and 2.93 % of unexplained accesses respectively.

6. Discussion

Healthcare data breaches are increasing. Logging, auditing, and monitoring of all electronic systems containing PHI can be useful in identifying unauthorized or breach accesses [13]. Several auditing tools based on machine learning algorithms are now available to hospitals to detect anomalies in PHI accesses. Validation of such tools will ensure successful identification of unauthorized accesses while accounting for dynamic hospital workflows. In this study, we have developed a framework to evaluate this kind of tool. Later, the framework was applied to validate Explanation-Based Auditing System (EBAS) auditing tool, implemented by the privacy departments of Mackenzie Richmond Hill Hospital (MRHH), to identify how accurately the tool categorizes MRHH staff accesses and to measure its performance over time. The black box method was used to develop the framework of the evaluation. Daily activities of the hospital staff, expert opinions from privacy officers and examples from the IPC have been used to design various

scenarios in this framework.

The case study conducted at MRHH demonstrated that the majority of the accesses were labeled as appropriate (98.02 % of total accesses). The remaining were unexplained accesses, mostly caused by staff who have unique workflows, staff with specialized roles, and staff from non-clinical departments. Moreover, the analysis identified a statistically significant *($P < 0.001$)* learning curve of 4 weeks and steady state after that on categorizing appropriate and unexplained accesses by the tool over time. We observed an increase in appropriate accesses and a decrease in unexplained accesses during weekends.

Analysis of the accesses of unexplained behaviours revealed important information on MRHH policies, workflow processes, and the tool. We found that aspects of the hospital's dynamic workflow, including phone calls from family or other departments, peer to peer consultation, and responses to patient complaints contributed to unexplained accesses since there were no work orders for these PHI accesses.

This evaluation method identified several other hospital policy related issues which can be considered to improve the identification of breach accesses. For example, this tool currently alerts high-risk accesses with flags when there is a last name match, full name match, neighbourhood match, and access to co-workers' PHI occurs in the same department. In addition, the tool also flags if any user views their own medical records to alert the privacy officer. All of these rules can be changed. If considers any other accesses as high-risk, for example, accesses related to sensitive or VIP patients, those accesses be introduced in the tool.

This study revealed that the successful deployment of this kind of tool is contingent on proper data mapping among various software systems of the hospitals to improve information synthesis. We also found that data quality is crucial for automated tools to provide more explanations on the hospital transactions as suggested by other researchers [40] as well.

A limitation of our study was that we could not use real patients' information to validate some of the appropriate and all the inappropriate accesses. However, fictitious data was used to manually create access logs to validate those scenarios and ensure technical soundness. Though we designed a wide range of scenarios to validate accesses of inappropriate behaviours, due to the complexity of writing manual logs representing these cases, we could not validate inappropriate scenarios related to accessing co-workers' profile, staff's emergency contact, accessing multiple patients' charts and if information on the care network was missing. However, the analysis on unexplained accesses revealed that missing information has a impact on the outcome of the tool.

This evaluation framework also helped to identify and rank top contributing staff, roles, and departments at MRHH and provided recommendations to reduce unexplained accesses. Further analysis to identify the impact of missing information and incorporating missing data would be a good start towardimprovements. Analysis of the workflows of top contributors (staff from various roles and departments) of unexplained accesses might help facilitate continuous improvement of automated auditing. Moreover, it would be valuable to perform a follow up study one or two-years post implementation after they have had an opportunity to improve the integrity of their data sources.

Summary points:

1 Automatic privacy tools for hospitals are available. However, empirical studies to assess their performances on dynamic hospital workflows were not found
2 Moreover, no specific guidelines are available to assess the effectiveness of these automated privacy tools for hospitals.
3 This study developed an evaluation framework to assess such kind of privacy auditing tools.
4 Later, the evaluation framework was applied to assess the effectiveness of a machine learning algorithm based automatic privacy tool used by Mackenzie Richmond Hill Hospital, Ontario, Canada on their workflows.

Funding

The project was funded by the Ontario Center of Excellence, Canada through their REACH Program.

Declaration of Competing Interest

None of the two authors have any conflict of interests and there is no financial involvement in this research that can influence the results.

Acknowledgements

Authors express sincere gratitude to Jasmina Germanski, Manager, Privacy and Information Security, MRHH for providing the opportunity to embark on this project and her continuous support and valuable insights in this evaluation study. The authors are sincerely grateful to Richard Tam, Executive Vice President and Chief Administrative Officer, Mackenzie Health; Dr. Aviv Gladman, Chief Information Officer and Chief Medical Information Officer, Mackenzie Health, and Diane Salois-Swallow, Senior Advisor, Mackenzie Innovation Institute, Mackenzie Health for their continuous support and valuable feedback in this evaluation study. The authors also want to show gratitude to EPIC analytics team, MRHH technical team, Privacy officer from Michael Garron Hospital and Privacy officer from Markham-Stouffville Hospital for their valuable time and tremendous support in the completion of the study.

Appendix A. Supplementary data

Supplementary material related to this article can be found, in the online version, at doi:https://doi.org/10.1016/j.ijmedinf.2020.104123.

References

[1] J. Adler-Milstein, A.J. Holmgren, P. Kralovec, C. Worzala, T. Searcy, V. Patel, Electronic health record adoption in US hospitals: the emergence of a digital "advanced use" divide, J. Am. Med. Inform. Assoc. 24 (6) (2017) 1142–1148.
[2] V. Liu, M.A. Musen, T. Chou, Data breaches of protected health information in the United States, Jama 313 (14) (2015) 1471–1473.
[3] A. Appari, M.E. Johnson, Information security and privacy in healthcare: current state of research, Int. J. Internet Enterp. Manag. 6 (4) (2010) 279–314.
[4] J.L. Fernández-Alemán, I.C. Señor, P.Á.O. Lozoya, A. Toval, Security and privacy in electronic health records: a systematic literature review, J. Biomed. Inform. 46 (3) (2013) 541–562.
[5] S. Choi, M.E. Johnson, Do hospital data breaches reduce patient care quality? In14th Workshop on the Economics of Information Security (WEIS), San Diego, CA, USA, 2017, pp. 26–27.
[6] L. Ponemon, Ponemon Institute Cost of a Data Breach Study, 26-Jul-2017. [Online]. Available: https://securityintelligence.com/media/2017-ponemon-institute-cost-of-a-data-breach-study/ [Accessed 20 February 2019]. (2017).
[7] L. Liu, M. Han, Y. Wang, Y. Zhou, Understanding data breach: a visualization aspect, International Conference on Wireless Algorithms, Systems, and Applications (2018) 883–892 Springer.
[8] M.S. Jalali, J.P. Kaiser, Cybersecurity in hospitals: a systematic, organizational perspective, J. Med. Internet Res. 20 (5) (2018) e10059 May 28.
[9] Per-Record Cost of Data Breaches Increasing," Relias Media - Continuing Medical Education Publishing, 01-Sep-2017. [Online], (2020) Available: https://www.reliasmedia.com/articles/141353-per-record-cost-of-data-breaches-increasing [Accessed 20 February 2019].
[10] F. Donovan, Healthcare Data Breach Costs Remain Highest Among Industries," HealthITSecurity, 16-Jul-2018. [Online], (2020) Available: https://healthitsecurity.com/news/healthcare-data-breach-costs-remain-highest-among-industries [Accessed 20 February 2019].
[11] K. Abouelmehdi, A. Beni-Hessane, H. Khaloufi, Big healthcare data: preserving security and privacy, J. Big Data 5 (1) (2018) 1.
[12] A.A. Boxwala, et al., Using statistical and machine learning to help institutions

detect suspicious access to electronic health records, J. Am. Med. Inform. Assoc. 18 (4) (2011) 498–505.
[13] Detecting and Deterring Unauthorized Access to Personal Health Information, IPC, 2015 28-Jan-2015. [Online]. Available: https://www.ipc.on.ca/resource/detecting-and-deterring-unauthorized-access-to-personal-health-information/ [Accessed 21 February 2019]..
[14] H.K. Patil, R. Seshadri, Big data security and privacy issues in healthcare, 2014 IEEE International Congress on Big Data, Dallas, US, 2014, pp. 762–765.
[15] Summary of the HIPAA Security Rule, HHS.gov, 2013 26-Jul-2013. [Online]. Available: https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html [Accessed 21 February 2019].
[16] A.K. Menon, et al., Detecting inappropriate access to electronic health records using collaborative filtering, Mach. Learning 95 (1) (2014) 87–101.
[17] D. Fabbri, K. LeFevre, Explanation-based auditing, Proc. VLDB Endowment 5 (1) (2011) 1–12.
[18] D. Fabbri, K. LeFevre, Explaining accesses to electronic medical records using diagnosis information, J. Am. Med. Inform. Assoc. 20 (1) (2012) 52–60.
[19] Hospitals Range in How Actively They Audit Records, Canadian Healthcare Technology, 2015 07-Jan-2015. [Online]. Available: https://www.canhealth.com/2015/01/07/hospitals-range-in-how-actively-they-audit-records/ [Accessed 24 February 2019].
[20] M. Krousel-Wood, A.B. Mccoy, C. Ahia, E.W. Holt, D.N. Trapani, Q. Luo, E.G. Price-Haywood, E.J. Thomas, D.F. Sittig, R.V. Milani, Implementing electronic health records (EHRs): health care provider perceptions before and after transition from a local basic EHR to a commercial comprehensive EHR, J. Am. Med. Inform. Assoc. 25 (6) (2017) 618–626.
[21] J. Bower, C. Boateng, Meeting the privacy officer challenge: outsourcing might Be the answer, Journal of Health Care Compliance (March–April) (2011) 33.
[22] S.A. Nancarrow, A.M. Borthwick, Dynamic professional boundaries in the healthcare workforce, Sociol. Health Illn. 27 (7) (2005) 897–919.
[23] S.M.R. Islam, D. Kwak, M.H. Kabir, M. Hossain, K.-S. Kwak, The internet of things for health care: a comprehensive survey, IEEE Access 3 (2015) 678–708.
[24] S. Nidhra, J. Dondeti, Black box and white box testing techniques-a literature review, Int. J. Embedded Syst. Appl. (IJESA 2 (2) (2012) 29–50.
[25] H.K. Leung, P.W. Wong, A study of user acceptance tests, Softw. Qual. J. 6 (2) (1997) 137–149.
[26] K. Ganesh, S. Mohapatra, S.P. Anbuudayasankar, P. Sivakumar, "User Acceptance Test" in Enterprise Resource Planning. Fundamentals of Design and Implementation, Springer International Publishing, Switzerland, 2014, pp. 123–127.
[27] R. Miller, C. Collins, Acceptance testing, Proc. XPUniverse Conf. 238 (2011).
[28] I. Ali, A Comparison Between Black Box and White Box Testing, Interesting Results in Computer Science and Engineering, 2009.
[29] Ö. Kafali, J. Jones, M. Petruso, L. Williams, M.P. Singh, How good is a security policy against real breaches? A HIPAA case study, 2017 IEEE/ACM 39th International Conference on Software Engineering (ICSE) (2017) 530–540.
[30] S. Lisbon, E. Rice, Case study: information security risk assessment for a small healthcare clinic using the security risk assessment tool provided by HealthIT. gov, Midwest Instruction and Computing Symposium, La Crosse, WI, 2017.
[31] T. Floyd, M. Grieco, E.F. Reid, Mining hospital data breach records: cyber threats to us hospitals, 2016 IEEE Conference on Intelligence and Security Informatics (ISI) (2016) 43–48.
[32] S.J. Blanke, E. McGrady, When it comes to securing patient health information from breaches, your best medicine is a dose of prevention: a cybersecurity risk assessment checklist, J. Healthc. Risk Manag. 36 (1) (2016) 14–24.
[33] C.M. Pugh, Electronic Health Records, Physician Workflows and System Change: Defining a Pathway to Better Healthcare, (2019).
[34] N. Prinyapol, J.P. Fan, S. Lau, A Hospital Based Dynamic Platform Workflow Management, (2009).
[35] M.H. Gabriel, A. Noblin, A. Rutherford, A. Walden, K. Cortelyou-Ward, Data breach locations, types, and associated characteristics among US hospitals, Am. J. Manag. Care 24 (February 2) (2018) 78–84.
[36] C. Czeschik, Black market value of patient data, Digital Marketplaces Unleashed Anonymous Springer, (2018), pp. 883–893.
[37] R.O. Koyame-Marsh, J.L. Marsh, Data breaches and identity theft: costs and responses, Iosr J. Econ. Financ. 5 (6) (2014) 36–45.
[38] Future of Smart Hospitals Concept Definition, Application, and Growth Opportunities, Frost and Sullivan, 2017.
[39] We Streamline EHR Access Audits, Maize Analytics, 2019 [Online]. Available: https://www.maizeanalytics.com/ [Accessed: 1 December 2019].
[40] A. McLeod, D. Dolezel, Cyber-analytics: modeling factors associated with healthcare data breaches, Decis. Support Syst. 108 (2018) 57–68.